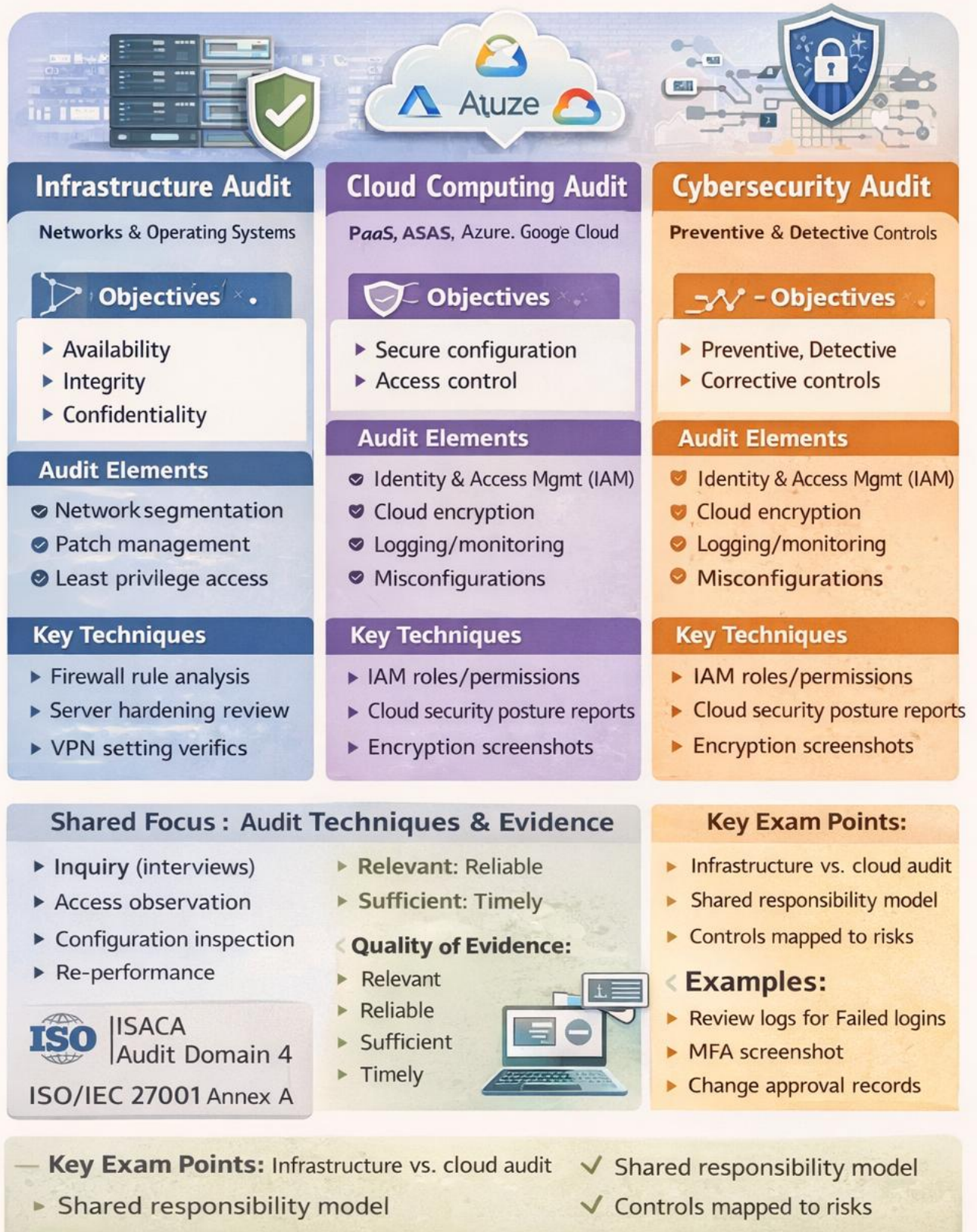


CMT 446 – Information Systems Audit

Module 4: Infrastructure, Cloud, and Cybersecurity Audits

Infrastructure, Cloud, and Cybersecurity Audits



“An auditor does not secure systems — an auditor assures trust.”

Slide 1: Module Context & Auditor's Role

Purpose of Module 4

- Shift from *policy and methodology* to **technical assurance**
- Focus on **how auditors gain confidence** in IT infrastructure and security controls

Why This Matters

- Most business risk today resides in:
 - Networks
 - Cloud platforms
 - Cybersecurity controls

Auditor's Role

- Independent assurance (not system administration)
- Validate **design, implementation, and effectiveness** of controls

Framework Alignment

- ISACA Audit Domain 4
 - ISO/IEC 27001 Annex A (Technical & Operational Controls)
-

Slide 2: Infrastructure Audit – Scope and Objectives

What Is IT Infrastructure?

- Networks (LAN, WAN, Wi-Fi)
- Servers (on-premise & virtual)
- Endpoints
- Operating systems

Audit Objectives

- Availability: systems work when needed
- Integrity: systems process data correctly
- Confidentiality: access is controlled

Typical Audit Questions

- Who can access the infrastructure?
- Are changes controlled and logged?
- Are vulnerabilities identified and remediated?

Key Risk

Infrastructure failures cascade into business failures

Slide 3: Network Audit – Core Focus Areas

Key Network Components

- Firewalls
- Routers & switches
- VPNs
- Intrusion detection/prevention systems

Audit Focus

- Network segmentation
- Firewall rule management
- Secure remote access
- Logging and monitoring

Common Findings

- Over-permissive firewall rules
- No periodic review of network access
- Weak VPN authentication

Evidence Examples

- Firewall configuration extracts
 - Network diagrams
 - Access review sign-offs
-

Slide 4: Operating System & Server Audits

Scope

- Windows / Linux servers
- Virtual machines
- Patch management processes

Audit Objectives

- Hardened configurations
- Least-privilege access
- Secure administrative controls

Key Controls

- Patch management
- Configuration baselines
- Privileged access management (PAM)

Audit Red Flags

- Shared admin accounts
 - Unsupported OS versions
 - No hardening standards
-

Slide 5: Cloud Computing – Why It Changes the Audit

Cloud Characteristics

- Shared responsibility model
- Elastic and on-demand resources
- Third-party controlled infrastructure

Auditor's Challenge

- You don't audit the cloud provider's data centre
- You audit **how the organization uses the cloud**

Audit Shift

- From hardware inspection → **configuration assurance**
- From ownership → **governance and accountability**

Examples

- AWS, Azure, Google Cloud
-

Slide 6: Cloud Audit – Key Control Domains

Primary Audit Areas

- Identity and Access Management (IAM)
- Data protection and encryption
- Logging and monitoring
- Secure configuration (misconfiguration risk)

Critical Questions

- Who has cloud admin access?

- Is data encrypted at rest and in transit?
- Are logs enabled and reviewed?

Evidence Sources

- Cloud security posture reports
 - IAM role listings
 - Encryption configuration screenshots
-

Slide 7: Cybersecurity Audit – Assurance Perspective

What Cybersecurity Audit Is

- Independent validation of security controls
- NOT penetration testing (but may review results)

Audit Scope

- Preventive controls
- Detective controls
- Corrective controls

Examples

- MFA enforcement
- SIEM monitoring
- Incident response procedures

Key Risk

Security tools exist, but are not used or monitored

Slide 8: Cybersecurity Control Mapping (ISO 27001 Annex A)

Core Annex A Areas Audited

- Access control
- Cryptography
- Operations security
- Communications security
- System acquisition & development

Audit Focus

- Control implementation

- Control effectiveness
- Evidence consistency

Common Gaps

- Policies exist, controls don't
 - Controls exist, evidence doesn't
 - Evidence exists, monitoring doesn't
-

Slide 9: Audit Techniques & Evidence Collection

Audit Techniques

- Inquiry (interviews)
- Observation
- Inspection
- Re-performance

Evidence Quality

- Relevant
- Reliable
- Sufficient
- Timely

Examples

- Screenshot of MFA enabled
- Log review extracts
- Change approval records

Professional Judgment

- Auditor evaluates *risk*, not perfection
-

Slide 10: Key Takeaways & Examiner Focus

Key Messages

- Infrastructure and cloud audits are **risk-driven**
- Cybersecurity assurance focuses on **control effectiveness**
- Evidence is central to audit credibility

Exam Focus Areas

- Difference between infrastructure vs cloud audit
- Shared responsibility model
- Mapping controls to risks

Closing Insight

“An auditor does not secure systems — an auditor assures trust.”

Module 4 Quiz: Infrastructure, Cloud & Cybersecurity Audits

SECTION A: QUESTIONS

Q1. What is the PRIMARY objective of an IT infrastructure audit?

- A. To configure network devices
 - B. To ensure systems meet availability, integrity, and confidentiality requirements
 - C. To perform penetration testing
 - D. To replace management responsibility
-

Q2. Which network audit issue presents the GREATEST security risk?

- A. Outdated network diagrams
 - B. Over-permissive firewall rules
 - C. Documented VPN procedures
 - D. Redundant network switches
-

Q3. Why does cloud computing significantly change the audit approach compared to on-premise infrastructure?

- A. Cloud systems cannot be audited
 - B. Cloud providers are responsible for all controls
 - C. Auditors focus on configuration and governance rather than physical infrastructure
 - D. Cloud systems have no security risks
-

Q4. In a cloud audit, which control is MOST critical for preventing unauthorized access?

- A. Physical server locks
 - B. Identity and Access Management (IAM)
 - C. Backup scheduling
 - D. Change management documentation
-

Q5. Which statement BEST describes the shared responsibility model in cloud computing?

- A. The customer controls everything
- B. The cloud provider controls everything
- C. Security responsibilities are shared between provider and customer
- D. Auditors replace the provider's security team

Q6. What is the PRIMARY purpose of a cybersecurity audit?

- A. To exploit system vulnerabilities
 - B. To independently assure the effectiveness of security controls
 - C. To replace incident response teams
 - D. To design security architecture
-

Q7. Which control is an example of a DETECTIVE cybersecurity control?

- A. Firewall rule configuration
 - B. Multi-factor authentication
 - C. Security Information and Event Management (SIEM) monitoring
 - D. Encryption of data at rest
-

Q8. Why is evidence quality critical in an IT audit?

- A. Auditors rely on opinions
 - B. Evidence supports audit conclusions and credibility
 - C. Evidence replaces audit planning
 - D. Evidence eliminates management judgment
-

Q9. Which audit technique involves verifying that a control actually works as intended?

- A. Inquiry
 - B. Observation
 - C. Re-performance
 - D. Documentation review
-

Q10. Which finding would MOST LIKELY indicate a weakness in cybersecurity governance?

- A. Regular log reviews
 - B. Clearly defined incident response procedures
 - C. Security tools deployed but not monitored
 - D. Documented access control policies
-
-

SECTION B: ANSWERS

A1. B – Ensure availability, integrity, and confidentiality

A2. B – Over-permissive firewall rules

A3. C – Focus shifts to configuration and governance

A4. B – Identity and Access Management (IAM)

A5. C – Responsibilities are shared

A6. B – Independent assurance of security controls

A7. C – SIEM monitoring

A8. B – Evidence supports conclusions and credibility

A9. C – Re-performance

A10. C – Security tools deployed but not monitored

Below are **scenario-based, open-ended CAT questions** for **CMT 446 – Information Systems Audit, Module 4 (Infrastructure, Cloud & Cybersecurity Audits)**.

They are designed to test **audit thinking, professional judgment, and application of frameworks** (not recall), and are **appropriate for a Continuous Assessment Test (CAT)**.

Module 4: Scenario-Based CAT Questions (Open-Ended)

Instructions to Students

Each question carries **10 marks**.

Support your answers using **audit principles, risk reasoning, and appropriate frameworks**.

Question 1: Network Infrastructure Audit Scenario

A medium-sized bank recently experienced intermittent system outages affecting ATM and online banking services. Management claims the issue was due to “temporary network congestion.”

As the IT auditor assigned to review the network infrastructure:

Required:

- a) Identify **four (4) key network audit areas** you would examine.
 - b) Explain **two (2) risks** associated with poor network configuration.
 - c) Describe the **audit evidence** you would collect to support your conclusions.
-

Question 2: Server and Operating System Controls Scenario

During an infrastructure audit, you discover that several production servers are running outdated operating systems that are no longer supported by the vendor.

Required:

- a) Explain why this situation represents a **significant audit risk**.
 - b) Identify **three (3) control weaknesses** likely to exist in this environment.
 - c) Recommend **appropriate audit actions** and management responses.
-

Question 3: Cloud Computing Audit Scenario

An organization migrated its customer database to a public cloud platform. Management states that “security is handled by the cloud provider,” and therefore internal controls are minimal.

Required:

- a) Explain the **shared responsibility model** in cloud computing.
- b) Identify **three (3) cloud control areas** the auditor should assess.
- c) Describe the **potential audit findings** if these controls are not implemented.

Question 4: Identity and Access Management (IAM) Scenario

While reviewing cloud access controls, you find that several former employees still have active administrative accounts.

Required:

- a) Identify the **key risks** associated with this finding.
 - b) Explain how this issue affects **confidentiality, integrity, and accountability**.
 - c) Propose **audit recommendations** to address the weakness.
-

Question 5: Cybersecurity Monitoring Scenario

An organization has invested heavily in cybersecurity tools, including firewalls, endpoint protection, and a SIEM platform. However, there is no evidence of regular log review or incident response testing.

Required:

- a) Explain why this situation represents a **governance failure** rather than a technology failure.
 - b) Identify **two (2) detective and two (2) corrective controls** that should exist.
 - c) Describe how an auditor would **verify control effectiveness**.
-

Question 6: Evidence and Audit Judgment Scenario

During a cybersecurity audit, management verbally assures you that multi-factor authentication (MFA) is enabled for all privileged users, but no screenshots or system reports are provided.

Required:

- a) Evaluate the **reliability of verbal assurance** as audit evidence.
 - b) Identify **two (2) additional audit procedures** you would perform.
 - c) Explain how insufficient evidence impacts **audit opinion and reporting**.
-

Question 7: Infrastructure vs Cloud Audit Comparison Scenario

Your audit firm is engaged to audit both an on-premise data centre and a cloud-hosted application for the same organization.

Required:

- a) Compare **two (2) key differences** in audit approach between on-premise and cloud environments.
 - b) Identify **unique risks** in each environment.
 - c) Explain how audit evidence differs in both cases.
-

Question 8: Incident Response and Cybersecurity Assurance Scenario

An organization suffered a ransomware attack but cannot demonstrate that incident response plans were tested before the incident.

Required:

- a) Explain the **audit implications** of untested incident response plans.
 - b) Identify **three (3) weaknesses** the auditor is likely to report.
 - c) Recommend **corrective actions** aligned with good cybersecurity governance.
-

Question 9: Professional Judgment Scenario

During an audit, management argues that implementing all recommended cybersecurity controls is “too expensive” and accepts the risk.

Required:

- a) Explain the role of **professional judgment** in this situation.
 - b) Describe how the auditor should **document and report** management’s risk acceptance.
 - c) Identify potential **ethical considerations** for the auditor.
-

Question 10: Integrated Assurance Scenario

An organization wants to align its IT audits with ISO/IEC 27001 and ISACA audit domains.

Required:

- a) Explain how **ISO/IEC 27001 Annex A** supports infrastructure and cybersecurity audits.
- b) Describe how **ISACA Audit Domain 4** enhances audit depth.
- c) Explain the value of **integrated assurance** to senior management.